بررسی تخصصی روش‌ها و تکنیک‌های نفوذ به وب‌سایت‌ها

تحلیل انواع آسیب‌پذیری‌ها، حملات سایبری و روش‌های سوءاستفاده از آن‌ها

چکیده

با گسترش فناوری‌های اینترنتی و افزایش وابستگی سازمان‌ها، شرکت‌ها و کاربران به سامانه‌های تحت وب، امنیت وب‌سایت‌ها به یکی از مهم‌ترین موضوعات دنیای فناوری اطلاعات تبدیل شده است. امروزه مهاجمان سایبری از روش‌های متنوعی برای شناسایی و سوءاستفاده از نقاط ضعف وب‌سایت‌ها استفاده می‌کنند. این روش‌ها از حملات شناخته‌شده‌ای مانند SQL Injection و Cross-Site Scriptingگرفته تا تکنیک‌های پیچیده‌تری مانندServer-Side Request Forgery ، HTTP Request Smuggling، Deserializationو حملات زنجیره تأمین نرم‌افزار را شامل می‌شوند.

در این مقاله، مهم‌ترین تکنیک‌های نفوذ به وب‌سایت‌ها بر اساس ساختار فنی و نوع آسیب‌پذیری بررسی می‌شوند. همچنین نحوه عملکرد کلی، اهداف، پیامدهای امنیتی و روش‌های پیشگیری از هر دسته مورد مطالعه قرار می‌گیرد. هدف اصلی، ارائه شناختی جامع از تهدیدات امنیتی وب و آشنایی با سازوکارهای دفاع در برابر آن‌هاست.

کلیدواژه‌ها :هک وب‌سایت، SQL Injection، XSS، SSRF، CSRF، IDOR، RCE، امنیتAPI ، آسیب‌پذیری وب، امنیت سایبری.

۱.مقدمه

وب‌سایت‌ها امروزه تنها مجموعه‌ای از صفحات اینترنتی نیستند؛ بلکه سامانه‌هایی پیچیده شامل پایگاه داده، سرور، رابط کاربری، API، سیستم احراز هویت و زیرساخت شبکه هستند. هرکدام از این اجزا ممکن است در صورت طراحی یا پیاده‌سازی نادرست، به نقطه‌ای برای نفوذ تبدیل شوند.

نفوذ به یک وب‌سایت الزاماً به معنای تغییر ظاهر آن نیست. گاهی مهاجم بدون ایجاد هیچ تغییر قابل مشاهده‌ای به اطلاعات کاربران دسترسی پیدا می‌کند، نشست‌های فعال را تصاحب می‌کند یا از طریق ضعف‌های منطقی، عملیات غیرمجاز انجام می‌دهد.

حملات وب را می‌توان بر اساس محل وقوع آسیب‌پذیری به چند گروه اصلی تقسیم کرد:

- حملات مربوط به پایگاه داده و تزریق دستورات
- حملات سمت مرورگر وJavaScript
- حملات احراز هویت و مدیریت نشست
- حملات کنترل دسترسی و مجوزها
- حملات مربوط به فایل‌ها و منابع سرور
- حملات API و سرویس‌های ارتباطی
- حملات زیرساختی و شبکه

- حملات مبتنی بر منطق تجاری برنامه

در ادامه، هرکدام از این دسته‌ها به‌صورت تخصصی بررسی می‌شوند.

۲ .حملات تزریق کد و دستورات(Injection Attacks)

حملات Injection از شناخته‌شده‌ترین و مهم‌ترین آسیب‌پذیری‌های برنامه‌های تحت وب هستند. در این حملات، داده‌ای که از طرف کاربر وارد برنامه می‌شود، به‌اشتباه به‌عنوان بخشی از یک دستور یا کد اجرایی تفسیر می‌شود.

۲-۱ .SQL Injection

SQL Injectionزمانی اتفاق می‌افتد که برنامه اطلاعات ورودی کاربر را بدون جداسازی مناسب وارد دستورهای پایگاه داده کند.

برای مثال، در یک سامانه ورود کاربران، اطلاعات نام کاربری و رمز عبور برای بررسی به پایگاه داده ارسال می‌شوند. اگر برنامه از کوئری‌های ناامن استفاده کند، ممکن است مهاجم بتواند منطق دستور SQL را تغییر دهد.

انواع مهم SQL Injection عبارت‌اند از:

- Union-based SQLi:ترکیب نتایج پرس‌وجوهای مختلف برای دسترسی غیرمجاز به داده‌ها.
- Error-based SQLi:استفاده از پیام‌های خطای پایگاه داده برای استنتاج اطلاعات.
- Boolean-based Blind SQLi:استخراج اطلاعات با بررسی تفاوت پاسخ در شرایط منطقی مختلف.
- Time-based Blind SQLi:استنتاج اطلاعات از طریق اندازه‌گیری زمان پاسخ سرور.
- Second-order SQLi:ذخیره داده ناامن و فعال شدن آسیب‌پذیری هنگام استفاده مجدد از آن.

پیامد این حمله می‌تواند افشای اطلاعات کاربران، تغییر داده‌ها، حذف اطلاعات و در شرایط خاص دسترسی به بخش‌های دیگر زیرساخت باشد.

راهکار اصلی مقابله با آن استفاده ازPrepared Statements ، محدود کردن دسترسی حساب پایگاه داده و اعتبارسنجی ورودی‌هاست.

۲-۲ .NoSQL Injection

این آسیب‌پذیری مشابه SQL Injection است، اما پایگاه داده‌های غیررابطه‌ای مانند MongoDB را هدف قرار می‌دهد. در این حالت، مهاجم ممکن است از ضعف در پردازش ورودی‌ها برای تغییر منطق پرس‌وجوها استفاده کند.

۲-۳ .سایر حملاتInjection

از دیگر انواع این خانواده می‌توان به موارد زیر اشاره کرد:

- LDAP Injection:دست‌کاری پرس‌وجوهای مربوط به سرویس.LDAP
- XPath Injection:دست‌کاری ساختار پرس‌وجوهای.XML
- OS Command Injection:ورود داده‌ای که به‌عنوان دستور سیستم‌عامل اجرا می‌شود.

- Code Injection: تزریق کد قابل اجرا در محیط برنامه.
- CRLF Injection: دست‌کاری ساختار پیام‌ها با تزریق کاراکترهای پایان خط.
- Expression Language Injection: سوءاستفاده از موتورهای ارزیابی عبارت.
- Header Injection: دست‌کاری هدرهای ارتباطی HTTP.

وجه مشترک تمام این حملات، اعتماد نامناسب برنامه به داده‌های ورودی است.

۳. حملات Cross-Site Scripting و آسیب‌پذیری‌های مرورگر

۳-۱ Cross-Site Scripting (XSS).

XSS یکی از مهم‌ترین آسیب‌پذیری‌های سمت کاربر است. در این حمله، مهاجم می‌تواند باعث شود داده کنترل‌شده توسط او به شکل کد JavaScript در مرورگر کاربران اجرا شود.

XSS معمولاً در سه نوع اصلی طبقه‌بندی می‌شود:

Stored XSS: محتوای آلوده در پایگاه داده یا سامانه ذخیره می‌شود و هنگام نمایش برای کاربران اجرا می‌شود.

Reflected XSS: ورودی مخرب در پاسخ همان درخواست کاربر بازتاب داده می‌شود.

DOM-based XSS: آسیب‌پذیری در نحوه پردازش اطلاعات توسط JavaScript و تغییر ساختار DOM مرورگر ایجاد می‌شود.

انواع دیگری نیز وجود دارند:

- Blind XSS
- Self-XSS
- Mutation XSS
- Universal XSS
- Second-order XSS
- Persistent DOM XSS

پیامدهای XSS شامل تغییر محتوای صفحه، نمایش فرم‌های جعلی، انجام عملیات ناخواسته و سوءاستفاده از اطلاعات در دسترس مرورگر است.

برای مقابله با این حمله باید خروجی‌های کاربر متناسب با محل نمایش ایمن‌سازی شوند، از روش‌های امن دست‌کاری DOM استفاده شود و سیاست Content Security Policy به‌درستی تنظیم شود.

۳-۲ Clickjacking .

درClickjacking ، مهاجم با ایجاد لایه‌های گرافیکی یا قاب‌های فریبنده تلاش می‌کند کاربر را به کلیک روی عناصر حساس یک وب‌سایت دیگر وادار کند.

استفاده از سیاست‌های X-Frame-Options و CSP frame-ancestors از روش‌های دفاعی مهم در برابر این حمله است.

۳-۳ DOM Clobbering .وXS-Leaks

DOM Clobberingاز تعامل نامناسب میان عناصر HTML و متغیرهای JavaScript سوءاستفاده می‌کند.

XS-Leaksنیز خانواده‌ای از حملات جانبی مرورگر است که در آن مهاجم تلاش می‌کند با مشاهده تفاوت رفتار مرورگر، اطلاعاتی درباره وضعیت یا داده‌های کاربران استنتاج کند.

۴ .حملات جعل درخواست و مدیریت نشست

۴-۱ Cross-Site Request Forgery (CSRF) .

CSRFزمانی رخ می‌دهد که مهاجم کاربر احراز هویت‌شده را وادار به ارسال درخواستی ناخواسته به یک وب‌سایت کند.

در این شرایط، مرورگر ممکن است کوکی احراز هویت کاربر را به درخواست اضافه کند و سرور آن را به‌عنوان درخواست معتبر بپذیرد.

این حمله در سامانه‌هایی که کنترل مناسبی روی منشأ درخواست ندارند، خطرناک است.

استفاده ازCSRF Token ، تنظیم صحیح SameSite و بررسی Origin از راهکارهای مقابله با آن هستند.

۴-۲ Session Hijacking .

در این حمله، مهاجم تلاش می‌کند شناسه نشست فعال یک کاربر را به دست آورد و از آن برای دسترسی به حساب کاربری استفاده کند.

۴-۳ Session Fixation .

درSession Fixation ، مهاجم از ضعف مدیریت شناسه نشست استفاده می‌کند تا کاربر با شناسه‌ای که از قبل تعیین شده وارد سامانه شود.

۴-۴ JWT Attacks .وToken Theft

توکن‌های JWT برای انتقال اطلاعات احراز هویت استفاده می‌شوند. پیکربندی نادرست الگوریتم اعتبارسنجی، مدیریت نامناسب کلیدها یا عدم بررسی امضای توکن می‌تواند باعث ایجاد آسیب‌پذیری شود.

از تکنیک‌های مرتبط می‌توان به موارد زیر اشاره کرد:

- JWT Algorithm Confusion
- JWT Key Confusion

- Refresh Token Replay
- Token Theft
- OAuth Misconfiguration
- Open Redirect

۵ .حملات کنترل دسترسی و افزایش سطح مجوز

یکی از خطرناک‌ترین اشتباهات در طراحی وب‌سایت‌ها، بررسی ناقص مالکیت منابع و مجوز کاربران است.

. IDOR۵-۱

در آسیب‌پذیریIDOR ، برنامه بدون بررسی مالکیت یک منبع، اجازه دسترسی به آن را بر اساس شناسه ارسالی می‌دهد.

برای مثال، ممکن است یک کاربر بتواند اطلاعات سفارش متعلق به کاربر دیگری را مشاهده کند؛ زیرا سرور صرفاً شناسه سفارش را بررسی کرده است.

BFLAو. BOLA ۵-۲

BOLAبه نقص کنترل دسترسی در سطح اشیای API اشاره دارد.

BFLAنیز زمانی رخ می‌دهد که کاربر بتواند عملیاتی را اجرا کند که مجوز انجام آن را ندارد؛ مانند فراخوانی عملیات مدیریتی.

. Privilege Escalation۵-۳

این حمله شامل افزایش سطح دسترسی از یک سطح محدود به سطح بالاتر است.

دو نوع مهم آن عبارت‌اند از:

- :Vertical Privilege Escalationتبدیل دسترسی کاربر عادی به دسترسی مدیریتی.
- :Horizontal Privilege Escalationدسترسی به اطلاعات یا منابع کاربران دیگر در همان سطح دسترسی.

۵-۴ .سایر آسیب‌پذیری‌های دسترسی

Forced Browsing، Authorization Bypass، Parameter Tampering، Mass Assignmentو Multi-Tenant Isolation Bypass از دیگر تکنیک‌های این خانواده هستند.

راهکار اصلی مقابله، بررسی مجوز در سمت سرور برای هر عملیات و هر منبع است.

۶ .حملاتSSRF ، فایل و منابع داخلی سرور

. Server-Side Request Forgery (SSRF)۶-۱

SSRFزمانی رخ می‌دهد که مهاجم بتواند از طریق یک برنامه آسیب‌پذیر، سرور را به ارسال درخواست به مقصدی غیرمجاز وادار کند.

انواع آن عبارت‌اند از:

- Blind SSRF
- Cloud Metadata SSRF
- SSRFمبتنی بر تغییر مسیر
- SSRFناشی از اعتبارسنجی ناقصDNS

این آسیب‌پذیری می‌تواند باعث دسترسی غیرمجاز به سرویس‌های داخلی و افشای اطلاعات زیرساخت شود.

۶-۲Path Traversal .

در این حمله، برنامه مسیر فایل را به‌درستی محدود نمی‌کند و ممکن است کاربر بتواند به فایل‌هایی خارج از پوشه مجاز دسترسی پیدا کند.

۶-۳ Local File Inclusion .وRemote File Inclusion

LFIمربوط به بارگذاری ناامن فایل‌های محلی و RFI مربوط به وارد کردن فایل از منابع خارجی است.

۶-۴Unrestricted File Upload .

در این آسیب‌پذیری، سامانه محدودیت امنیتی مناسبی برای فایل‌های بارگذاری‌شده ندارد. این موضوع می‌تواند زمینه‌ساز ذخیره محتوای مخرب یا اجرای ناخواسته فایل در محیط سرور شود.

۶-۵ .سایر حملات فایل

- Arbitrary File Read
- Arbitrary File Write
- Zip Slip
- Archive Bomb
- MIME Type Spoofing
- Double Extension Attack
- Null Byte Injection

۷ .حملات مربوط به API و معماری نرم‌افزار

با گسترش برنامه‌های تک‌صفحه‌ای مانند React و معماری‌های مبتنی برAPI ، امنیت نقاط انتهایی سرویس‌ها اهمیت بیشتری پیدا کرده است.

مهم‌ترین آسیب‌پذیری‌های API عبارت‌اند از:

- Broken Authentication
- BOLA
- BFLA
- Excessive Data Exposure
- Mass Assignment
- GraphQL Injection
- GraphQL Introspection Abuse
- GraphQL Denial of Service
- WebSocket Hijacking
- API Rate Limit Bypass
- Improper Inventory Management

همچنین در سمت سرور آسیب‌پذیری‌هایی مانندDeserialization ، PHP Object Injection، Java Deserialization، Prototype Pollutionو Server-Side Template Injection می‌توانند خطرات جدی ایجاد کنند.

یکی دیگر از تهدیدات مهم، Remote Code Executionیا RCE است. در این حالت، نقص امنیتی ممکن است امکان اجرای کد از راه دور روی سامانه آسیب‌پذیر را فراهم کند.

۸ .حملات زیرساختی، شبکه و زنجیره تأمین

۸-۱Distributed Denial of Service .

در حملهDDoS ، مهاجم با ارسال حجم زیادی از ترافیک یا درخواست‌های پردازشی باعث مصرف منابع و از دسترس خارج شدن سرویس می‌شود.

انواع مهم آن عبارت‌اند از:

- Volumetric Attacks
- Protocol Attacks
- Application Layer Attacks
- SYN Flood

- Slowloris
- DNS Amplification

۸-۲. DNS Hijacking و Subdomain Takeover

درDNS Hijacking ، تنظیمات DNS به‌صورت غیرمجاز تغییر می‌کنند.

درSubdomain Takeover ، مهاجم ممکن است یک زیردامنه رهاشده یا پیکربندی‌نشده را تصاحب کند.

۸-۳. Man-in-the-Middle .

در این حمله، مهاجم در مسیر ارتباطی میان دو طرف قرار می‌گیرد و تلاش می‌کند اطلاعات را مشاهده یا تغییر دهد.

۸-۴. Supply Chain Attack .

در این نوع حمله، به‌جای هدف قرار دادن مستقیم وب‌سایت، یکی از اجزای مورد اعتماد آن مانند کتابخانه‌ها، بسته‌های نرم‌افزاری یا افزونه‌ها هدف قرار می‌گیرد.

Dependency Confusionو Dependency Hijacking از نمونه‌های مرتبط با این خانواده هستند.

۸-۵. Zero-Day Exploit .

Zero-Dayبه آسیب‌پذیری‌ای گفته می‌شود که در شرایط موردنظر هنوز اصلاحیه عمومی مؤثری برای آن در دسترس نیست.

این آسیب‌پذیری‌ها می‌توانند حتی نرم‌افزارهای به‌روز را نیز تحت تأثیر قرار دهند.

۹ .حملات مبتنی بر منطق تجاری و رفتار کاربران

تمام آسیب‌پذیری‌ها ناشی از خطاهای فنی نیستند. برخی از آن‌ها در منطق تجاری سامانه ریشه دارند.

نمونه‌های مهم عبارت‌اند از:

- Price Manipulation:دست‌کاری قیمت محصولات.
- Coupon Abuse:سوءاستفاده از منطق کدهای تخفیف.
- Payment Bypass:دور زدن تأیید واقعی پرداخت.
- Race Condition:وابستگی نتیجه عملیات به زمان‌بندی درخواست‌های هم‌زمان.
- TOCTOU:تغییر وضعیت یک منبع میان بررسی و استفاده از آن.
- Negative Quantity Attack:سوءاستفاده از پذیرش تعداد منفی.
- Inventory Manipulation:دست‌کاری منطق موجودی انبار.
- Transaction Replay:تکرار غیرمجاز عملیات مالی.

- Workflow Bypass: دور زدن مراحل اجباری فرایندها.
- Double Spending: استفاده چندباره از یک اعتبار یا دارایی.

برای مثال، در یک فروشگاه اینترنتی اگر سرور قیمت نهایی را از داده ارسالی مرورگر بپذیرد، ممکن است امکان دست‌کاری مبلغ سفارش ایجاد شود. قیمت و محاسبات مالی باید همیشه در سمت سرور و بر اساس داده معتبر محاسبه شوند.

۱۰. جمع‌بندی و نتیجه‌گیری

بررسی تکنیک‌های مختلف نفوذ نشان می‌دهد که امنیت وب‌سایت تنها به محافظت از رمز عبور یا نصب یک فایروال محدود نمی‌شود. هر بخش از یک سامانه، از رابط کاربری و API گرفته تا پایگاه داده، سرور و زیرساخت شبکه، می‌تواند در معرض تهدید قرار داشته باشد.

حملاتی مانند SQL Injection و XSS از ضعف در پردازش ورودی‌ها استفاده می‌کنند؛ CSRF و Session Hijacking مدیریت نشست کاربران را هدف قرار می‌دهند؛ IDOR و BOLA از نقص کنترل دسترسی بهره می‌برند؛ SSRF و RCE می‌توانند امنیت زیرساخت سرور را تهدید کنند و حملات Business Logic نیز از اشتباهات طراحی فرایندهای تجاری سوءاستفاده می‌کنند.

برای مقابله با این تهدیدات، استفاده از کدنویسی امن، کنترل دقیق دسترسی‌ها، به‌روزرسانی نرم‌افزارها، مدیریت صحیح نشست‌ها، ثبت رویدادهای امنیتی، بررسی وابستگی‌ها و انجام آزمون نفوذ مجاز ضروری است.

در نهایت باید توجه داشت که هیچ وب‌سایتی را نمی‌توان صرفاً با استفاده از یک ابزار یا روش، کاملاً ایمن دانست. امنیت یک فرایند مستمر است که نیازمند بررسی، اصلاح و نظارت دائمی خواهد بود.

منابع و مراجع

۱. OWASP Foundation – Web Security Testing Guide .
https://owasp.org/www-project-web-security-testing-guide/

۲. OWASP – Web Security Academy .
https://portswigger.net/web-security

۳. OWASP – API Security Project .
https://owasp.org/www-project-api-security/

۴. MITRE – Common Weakness Enumeration (CWE) .
https://cwe.mitre.org/

۵. National Vulnerability Database (NVD) .
https://nvd.nist.gov/

۶. OWASP – Top 10 Web Application Security Risks .
https://owasp.org/www-project-top-ten/

. OWASP – Cheat Sheet SeriesY

https://cheatsheetseries.owasp.org/